

NIST CSF Risk Prioritization Matrix

Priority	Function	Gap	Rationale	Risk Impact	Recommended Treatment	Dependency	Target Sequence	Status
Critical	DETECT	Coverage gap + no MTTD metric	Foundational — weak detection undermines RESPOND and RECOVER even where those functions otherwise perform well	High	Extend monitoring to all critical assets including legacy systems and establish monthly MTTD reporting	None	1	Open
High	PROTECT	Awareness below target	Directly reduces phishing and social engineering exposure; closable within one additional training cycle	High	Increase security awareness completion to 95%+ and monitor completion monthly	None	2	Open
High	RESPOND	No tested incident response plan	Unverified response capability is a significant unknown risk with relatively low cost to close through a tabletop exercise	High	Conduct annual incident response tabletop exercise and document lessons learned	DETECT improvement s support response validation	3	Open
Medium	GOVERN	Untiered vendor risk	Functioning process exists; improvement is needed to focus oversight on higher-risk suppliers	Medium	Implement vendor criticality tiers and include supply chain risk reporting in Management Reviews	Vendor inventory	4	Open
Medium	IDENTIFY	Manual-only asset discovery	Existing manual process functions; automation is primarily a coverage and efficiency improvement	Medium	Implement automated asset discovery and identify unmanaged or shadow cloud resources	Cloud and enterprise asset inventory	5	Open
Medium	RECOVER	Untested recovery communication	Core recovery capability is already strong because restoration is tested; communication requires validation	Medium	Test the recovery communication plan alongside each restoration exercise and record lessons learned	Backup restoration testing	6	Open